

BURSA MALAYSIA BERHAD

REGULATORY AND SECURITY CONTROLS WORKING GROUP RECOMMENDATION PAPER ON REGULATORY AND CYBERSECURITY CONTROLS FOR BROKERS

This Recommendation Paper is divided into the following sections: -

Section	Title
1	INTRODUCTION 1.1 Overview 1.2 Objectives
2	IT AND CYBERSECURITY STANDARDS: 2.1 Security Access Controls 2.2 Threat Detection & Protection 2.3 Patch Management 2.4 Infrastructure & Operation Resilience 2.5 Recovery Planning 2.6 Oversight of Technology Service Providers 2.7 Incident Management 2.8 Training and Awareness 2.9 Dedicated Cybersecurity Role Establishment Through Internal or External Resources
3	IMPLEMENTATION TIMELINE AND APPLICABILITY
4	REGULATORY ALIGNMENT
5	CONTACT INFORMATION
	APPENDIX Appendix A – Categorisation of Brokers

1. INTRODUCTION

1.1 Overview

On 24 April 2025, a cyber incident involving unauthorised access and trades executed through Participating Organisations' systems exposed critical vulnerabilities within the broking ecosystem. This event underscored the urgent need for enhanced cybersecurity and regulatory controls across the industry.

In response, Bursa Malaysia convened an Industry Dialogue on 11 June 2025 with market participants and the Association of Stockbroking Companies Malaysia ("ASCM") to discuss the implications of the breach and gather initial feedback. Subsequently, Bursa Malaysia announced the formation of the Regulatory and Security Controls Working Group ("RSWG") on 20 June 2025.

The RSWG is a collaborative initiative comprising Bursa Malaysia, broking industry representatives, and cybersecurity experts. Its mandate is to strengthen the regulatory and cybersecurity framework for the broking industry specifically for all Participating Organisations ("POs") and Trading Participants ("TPs") (collectively "Brokers") in Malaysia by:

- Enhancing regulatory and cybersecurity controls;
- Promoting industry-wide governance and risk management practices;
- Ensuring the resilience and integrity of the broking ecosystem.

To ensure the relevance and practicality of its recommendations, the RSWG conducted a Focus Group Session on 23 July 2025, engaging key stakeholders to gather insights and feedback. The resulting Recommendation Paper reflects these deliberations and is designed to be both actionable and scalable.

The paper introduces a set of standards and controls, structured around a risk-based categorisation framework for POs. The risk-based grouping applies specifically to securities brokers i.e. POs, which generally have greater exposure to retail investors. In contrast, derivatives brokers i.e. TPs tend to serve more institutional clients. Importantly, the classification is not a reflection of a PO's quality or capability, but rather a mechanism to align regulatory expectations with relative risk levels. The full list of POs under each group is provided in **Appendix A**.

The paper also supports a phased rollout strategy, prioritising foundational elements such as people, processes, and governance, before progressing to system and tool-related implementations to ensure reasonable compliance across all Brokers.

Brokers are expected to assess their systems against these recommendations and take appropriate steps to align with the standards set forth, in support of a more secure and well-governed broking ecosystem.

1.2 Objectives

The primary objective of this Recommendation Paper is to strengthen the regulatory and cybersecurity posture of Brokers within the Malaysian broking ecosystem. This is achieved through the establishment of a structured framework of controls and practices that are both enforceable and adaptable to varying operational contexts.

Specifically, the paper seeks to:

- **Establish Baseline Security Standards**
Define a minimum set of standards and controls that all Brokers must implement to ensure consistent and robust cybersecurity and regulatory compliance across the industry.
- **Promote Continuous Improvement**
Encourage Brokers to go beyond baseline requirements where feasible, in alignment with evolving threat landscapes and operational maturity.
- **Support Proportionate Implementation**
Introduce a group-based classification framework to enable differentiated application of controls based on each broker's market presence, risk exposure, and operational capabilities.
- **Enhance Industry-Wide Resilience**
Foster a more secure and well-governed broking ecosystem by addressing systemic vulnerabilities and promoting collective accountability among market participants.
- **Align with Regulatory Expectations**
Ensure consistency with existing regulatory frameworks and guidelines, including Bursa Malaysia's IT Security Standards, the Guidelines on Technology Risk Management ("GTRM"), and the Risk Management in Technology ("RMiT") issued by Bank Negara Malaysia.

2. IT AND CYBERSECURITY STANDARDS

This section outlines the essential IT and cybersecurity controls that all Brokers are expected to implement. These “must-have” requirements serve as baseline standards to strengthen digital resilience and safeguard the integrity of their systems, networks and operating environment. Implementation timeline is tailored according to each broker’s classification group as per in **Appendix A**.

2.1 Security Access Controls

Objective:

To ensure that access to systems, applications, and data is appropriately restricted based on user roles and responsibilities, thereby minimising unauthorised access and safeguarding sensitive information.

Requirements:

Areas	Standards	Guidance
(a) Principle of Least Privilege	Enforce the principle of least privilege at user level. For automated systems, implementation may be phased based on operational feasibility.	Session security shall include: • idle timeout ≤15 minutes, • re-authentication for order placement and funds movement, • concurrent-session caps, • device binding, impossible-travel detection, and • Internet Protocol (“IP”) reputation checks.
(b) Role-Based Access Control (“RBAC”)	(i) Establish clearly defined roles with associated access permissions. (ii) Users assigned to roles based on their responsibilities (e.g., trading desk, back office, IT support).	• Service accounts shall have named owners, vaulted secrets, least-privilege scopes, and secret rotation at least every 90 days (Application Programming Interface (“API”) keys every 30 days).

Areas	Standards	Guidance
(c) Strong Authentication Mechanisms	(i) Multi-factor authentication ("MFA") must be mandated to all critical systems, internet facing applications and privileged accounts. (ii) The MFA must comprise two-factor authentication at a minimum and be implemented for both employee's (i.e. VPN or Remote Access) and customer's authentication process (Online Trading). (iii) MFA must be implemented by adopting at least one or more of the following authentication methods: (a) something that a user knows (e.g. password, PIN, passphrase, response to a security question) (b) something that a user has (e.g. mobile phone to receive a one-time SMS code or mobile authenticator app code, smart card, token) (c) something that unique about a user (e.g. biometric-based such as fingerprints, facial recognition, voice recognition, retina scans)	
(d) Periodic Access Review	(i) Promptly review and remove any terminated employees, agents, and those with changed roles. (ii) Review of access for all users must be carried out at least once a year.	
(e) Segregation of Duties ("SoD")	Prevent single person for performing a complete sensitive process.	
(f) Physical Access Control	Monitor physical access to facilities and systems.	

Areas	Standards	Guidance
(g) Logging and Monitoring	Log all access attempts (successful and failed), continuously monitor for suspicious activity, and retain all security logs for a minimum of three (3) years to support audit, investigation, and regulatory compliance.	Brokers are responsible for maintaining a comprehensive library of detection use cases, which should include scenarios such as Account Takeover incident, data exfiltration, lateral movement, execution of unsigned or side-loaded binaries, and abuse of cloud control-plane operations.
(h) Privileged Access Management ("PAM")	Implement a system to effectively manage, monitor, and secure privileged accounts by enforcing strong password policies. Session recording must be enabled for all privileged sessions.	- Session recording for privileged sessions may include: - Record keystrokes, commands, and screen activity. - Store recordings securely with access controls. - Use PAM tools that support real-time monitoring and alerting for suspicious behaviour.
(i) Just-in-Time (JIT) Access	JIT access is mandatory for all privileged accounts, with automatic expiry and approval workflows. Grant temporary privileged access only when needed.	Use a PAM solution that supports JIT access.
(j) Secure Session Management	Use secure session IDs, expiration, and invalidation mechanisms.	

2.2 Threat Detection & Protection

Objective:

To proactively identify, monitor, and respond to potential cybersecurity threats through the deployment of robust detection mechanisms and protective controls, thereby reducing the risk of system compromise and data breaches.

Requirements:

Areas	Standards	Guidance
(a) Advanced Endpoint Protection	Implement Next-generation antivirus ("NGAV") and endpoint detection and response ("EDR") solutions across all endpoints, with threat prevention configurations designed to proactively detect and block malicious activities.	
(b) Network Intrusion Detection/Prevention Systems ("IDPS")	Implement IDPS at network perimeters and critical internal segment, to monitor unauthorised access attempts and known attack patterns.	Security Operation Centre ("SOC") performance shall meet Priority 1 incident triage ≤15 minutes, containment ≤2 hours, and eradication plan ≤24 hours.
(c) Security Information and Event Management ("SIEM")	(i) Install strong intrusion detection devices to monitor network traffic on a real-time basis, such as SIEM. (ii) Aggregate and analyse security logs from multiple sources. (iii) Real-time alerts must be generated based on correlated events. A 24/7 capability for behavioural analytics and threat detection must be implemented.	- Implement system with Artificial Intelligence capability. - Include User and Entity Behaviour Analytics ("UEBA") and automated threat hunting features in SIEM for Group 1 and 2.
(d) Data Loss Prevention ("DLP")	(i) Implement solution(s) to prevent unauthorised transmission of sensitive client data and proprietary trading information. (ii) Data such as account numbers, personal identifiable information must be monitored and protected.	

Areas	Standards	Guidance
(e) Web Application Firewalls ("WAF")	Implement solution(s) to protect public-facing web applications, support geo-IP blocking and to protect against common web-based attacks.	
(f) Compromise Assessments ("CA")	(i) Perform periodic independent Compromise Assessments to detect signs of past or ongoing breaches. a. Group 1: Every 12 months b. Group 2 & Group 3: Every 24 months (ii) Assessment to include deep forensic analysis, threat hunting across endpoints, networks, and applications, and review of systems handling sensitive client data and financial transaction. (iii) Additionally, assessments should incorporate sector-specific threat profiles, holistic data collection, behavioural analytics, machine learning-based correlation, insider threat monitoring, and evaluation of third-party dependencies. (iv) A rapid response playbook should be developed to guide containment and remediation efforts, and findings must be summarised in board-level reports.	- A critical system refers to any application system, where failure of the system has the potential to significantly impair the PO's provision of services to clients or counterparties, business operations, financial position, reputation, or compliance with applicable laws and regulatory requirements. - Where feasible, assessments should also consider alignment with zero trust segmentation principles.
(g) Email and Web Security Gateways	Filter phishing and block malicious sites.	
(h) Encryption	Encryption to be implemented for data at rest and in transit across all critical systems.	

Areas	Standards	Guidance
(i) API Security Controls	API Security Controls must be in place where applicable including but not limited to: • Authentication & Authorisation (OAuth 2.0, API Keys) • Secure API Design & Configuration • API Gateway Management • Rate Limiting & Throttling • API Logging & Monitoring • API Inventory & Versioning • Secure Error Handling	
(j) Phishing/Fake Website Take-Down Services	Subscribe to specialised services for the detection and take-down of phishing sites and fake websites targeting the organisation or its customers, where feasible.	
(k) Vulnerability Scanning & Assessment	(i) Vulnerability Scanning & Assessment • Conduct regular vulnerability assessment on all internal and external servers. • For all critical systems, perform penetration testing at least once a year. (ii) Patching and Remediation • Prioritise patching based on the severity and potential impact of the discovered vulnerabilities. • Ensure that the most critical vulnerabilities are addressed first to reduce the highest risks.	• A critical system refers to any application system, where failure of the system has the potential to significantly impair the broker's provision of services to clients or counterparties, business operations, financial position, reputation, or compliance with applicable laws and regulatory requirements. • Internet-facing trading applications shall operate a coordinated vulnerability disclosure program proportionate to risk.

Areas	Standards	Guidance
(l) Adversarial Attack Simulation ("AASE") or Red-Teaming exercise	(i) Organise regular simulation of real-world attack scenarios. (ii) Threats simulation must be intelligence-led and designed to evaluate detection and response capabilities across people, process and technology.	- At least once every three years is the recommended baseline frequency for conducting AASE exercises for Brokers. - More frequent exercises may be warranted depending on: - The broker's risk profile - Changes in threat landscape - Criticality of systems and functions - Past incidents or findings from previous exercises
(m) Threat Intelligence Integration & Dark Web Monitoring	(i) Integrate external threat Intelligence feeds into security operations. (ii) Build capability to detect data leakages, including monitoring of dark web to detect credential leaks, or discussions targeting the firm. (iii) Promptly investigate identified leaks and remediate the gap.	
(n) Extended Detection and Response ("XDR")		Implement XDR solutions to provide holistic visibility and correlation across endpoints, networks, cloud, and identity for enhanced threat detection and response capabilities, where feasible.

2.3 Patch Management

Objective:

To ensure timely identification, testing, and deployment of software patches and updates, reducing vulnerabilities and maintaining the security and stability of IT systems.

Requirements:

Areas	Standards	Guidance
(a) Centralised Patch Management System	(i) Implement a centralised system for patch management. (ii) The centralised patch management system should include coverage for trading software and back-office applications. (iii) The system must maintain a real-time inventory of devices and applications, integrate with vulnerability scanners, and support audit logging for compliance monitoring.	• Implement a centralised patch management system using automated tools that can detect, test, deploy, and report on patches across all critical assets. • Test patches in a staging environment before deployment and ensuring timely updates, especially for high-risk vulnerabilities. • Scanning cadence shall be weekly (external perimeter), monthly (internal authenticated), and per release (web/API). • Product Owners must keep updated Software Bill of Material ("SBOMs") for systems under their responsibility and monitor/remediate any Common Vulnerabilities and Exposures ("CVEs") found in those components.
(b) Third-Party Software Patching	(i) Establish a formal process for managing third-party and vendor supplied systems, (ii) Market data and trading related third-party applications to be covered under this process.	• For third-party and vendor supplied systems, to include an attestation of patching compliance from vendors every quarter.

Areas	Standards	Guidance
(c) End-of-Life ("EOL") Tracking & Management	(i) Establish a process to track and manage EOL and End of Support ("EOS") dates for critical systems, applications, databases, hardware, and appliances. (ii) Implement proactive timeline for replacing and upgrading EOL/EOS components. (iii) EOL and EOS status and replacement plans to be reported and the associated risks to be accepted by senior management and the Board of Directors. (iv) If Brokers determine that there is a need to continue leveraging on critical technologies hosted on obsolete systems, the Brokers must: • obtain formal approval from board/ senior management and define a validity period for the continued use of such critical IT systems, aligned with the level of identified risks and its corresponding risk mitigation strategies; and • closely monitor, assess potential impact and establish risk mitigation strategies that is proportionate to the Brokers' risk tolerance for such critical IT systems.	
(d) Patch Testing & Rollback Plan	(i) Establish formal process for test patches in a non-production environment before deployment. (ii) Establish a roll-back plan in place for patch-related issues.	

Areas	Standards	Guidance
(e) Timely Patch Deployment	(i) Define strict timelines for deploying critical and high-severity patches. (ii) Zero-day vulnerabilities to be addressed immediately.	If a Common Vulnerabilities and Exposures ("CVE") is exploited (i.e., attackers are using it), an emergency change management and advisory meeting must be held within 24 hours to assess and approve necessary changes or mitigations.
(f) Compensatory Controls	Implement temporary security measures, such as virtual patching rules or application control policies, to shield vulnerable systems when immediate patch deployment is not feasible due to operational constraints.	

2.4 Infrastructure & Operation Resilience

Objective:

To ensure the continuity, reliability, and robustness of IT infrastructure and operations by implementing resilient architecture, redundancy measures, and recovery capabilities that minimise downtime and disruption in the face of adverse events.

Requirements:

Areas	Standards	Guidance
(a) Redundant Systems & High Availability	(i) Identify all redundant infrastructure components (e.g. servers, network devices, power supplies, diverse paths, and multiple Internet Service Providers ("ISPs"). (ii) Maintain necessary infrastructure redundancy to eliminate single points of failure and adopt high-availability solutions for all critical systems.	• High-availability solutions include among others deploying primary and secondary servers in separate locations, using clustered databases, redundant network paths, and automated failover mechanisms to ensure continuity of operations during system failures or disruptions. • Shall conduct auto-failover drills under load and verify RTO/RPO.
(b) Network Segmentation	Implement network segmentation to isolate critical systems (e.g. trading systems, client databases) from less sensitive networks, limiting the lateral movement of attackers in case of a breach.	• Critical environments shall implement tiered/micro-segmentation and baseline configuration compliance (CIS) with continuous monitoring.

Areas	Standards	Guidance
(c) Regular System Backups	(i) Establish a comprehensive backup strategy for critical data and system configurations. (ii) Perform regular backup, based on Brokers' backup and recovery policy and backups to be stored securely. (iii) Implement backups for critical systems to protect against ransomware.	• Backups should be performed at a frequency determined by the broker's risk tolerance and operational requirements, as defined in their backup and recovery policy. Backups must be securely stored to ensure data integrity and availability. • Backup strategies should incorporate among others air-gapped or immutable storage solutions to ensure resilience against ransomware, data corruption, and unauthorised access. • Brokers shall provision alternate connectivity (multi-carrier/segmented paths) and perform climate-risk drills (heat, flood, power) for sites and telecoms. • Backups shall be immutable and encrypted with Hardware Security Modules (HSM) and Key Management Systems (KMS)-backed keys.
(d) Capacity Planning & Scalability	(i) Continuously monitor system performance and capacity. (ii) Ensure infrastructure is able to handle peak trading volumes and planned growth without degradation.	
(e) Environmental Controls	(i) Implement robust environmental controls which include environmental monitoring with alerting for temperature, humidity, and power anomalies, for data centres and server rooms. (ii) Ensure controls are regularly tested and maintained.	

Areas	Standards	Guidance
(f) Monitoring & Alerting	Continuously monitor infrastructure health and performance with automated alerts for anomalies.	A monthly Key Risk Indicator ("KRI") pack shall be submitted to the board (e.g. open critical vulnerabilities, SLA breach, EOL exposure).
(g) Secure Configuration - Security Misconfiguration,	Ensure all infrastructure components, servers, and applications are securely configured, removing default credentials and unnecessary features.	
(h) Geographical Diversification	Utilise geographically diverse data centres or recovery sites for critical infrastructures.	

2.5 Recovery Planning

Objective:

To establish structured and tested recovery procedures that enable timely restoration of critical systems and data following a disruption, ensuring minimal impact on business operations and maintaining service continuity.

Requirements:

Areas	Standards	Guidance
(a) Business Continuity Plan ("BCP") Development	(i) Establish a comprehensive BCP which outlines procedures for responding-to and recovering-from disruptive events (e.g. cyberattacks, natural disasters). (ii) BCP must be reviewed regularly.	
(b) Disaster Recovery Plan ("DRP") for IT Systems	(i) Establish a detail DRP for IT systems covering data recovery, system restorations, and application recovery. (ii) DRP must include procedures for network re-establishment.	
(c) Regular Testing & Drills	(i) BCP, DRP must be tested at least once a year. (ii) Test to include failover scenarios and simulated cyberattacks.	
(d) Recovery Time Objective ("RTO") & Recovery Point Objective ("RPO")	(i) Define RTOs and RPOs for all critical business functions and IT systems. (ii) Objectives to be aligned with business impact assessment. (iii) Must ensure that critical third-party vendors are included in the assessment and determination of RTO and RPO as part of BCP.	- Brokers shall identify Important Business Services (IBS) and set impact tolerances (time/service levels). - Brokers shall scenario-test those tolerances at least annually (ransomware, corrupted market data, provider outage, mass Account Takeover), and keep an executive self-assessment updated yearly.

Areas	Standards	Guidance
(e) Communication & Notification Plan	Establish a communication plan for internal stakeholders, clients, regulators, and vendors during a recovery event: • Internal communication: Brief executives, IT teams, and relevant staff. • External communication: Notify regulators, law enforcement, clients, and partners as required. • Public relations: Prepare clear messaging to maintain trust and avoid misinformation.	
(f) Data Integrity Verification	Implement a process to verify the integrity and consistency of recovered data after an incident.	• Use techniques like checksums, hash comparisons, automated validation, and simulated recovery environments to ensure data integrity.
(g) Incident Documentation & Root Cause Analysis	(i) Record what happened: timeline, affected systems, data, and actions taken. (ii) Conduct post-incident forensic analysis to determine the root cause. (iii) Preserve evidence for legal, regulatory, or insurance purposes.	• Evidence of restoring time, data integrity (hashes) and stakeholder communications shall be retained.
(h) Technical Recovery	(i) Eradicate malicious code, backdoors, or persistence mechanisms. (ii) Restore systems, applications, and data from verified clean backups. (iii) Validate system integrity before bringing services back online. (iv) Patch vulnerabilities and apply hardening measures to prevent recurrence.	
(i) Legal, Compliance & Insurance	(i) Assess all legal obligations for breach disclosure (ii) Secure and maintain adequate cyber insurance coverage to protect the company from the financial impact of a cybersecurity incident.	• Work with legal counsel to manage liability.

2.6 Oversight of Technology Service Providers

Objective:

To ensure that third-party technology service providers adhere to the PO's and regulators' cybersecurity and operational standards, thereby minimising external risks and maintaining accountability across outsourced functions.

Requirements:

Areas	Standards	Guidance
(a) Due Diligence and Vendor Risk Assessment	(i) Conduct cybersecurity risk assessment of third-party technology service providers before engagement. (ii) The due diligence process must include evaluation of concentration risk. (iii) Potential dependencies on a single/ limited number of providers must be identified and strategies must be in place to manage or mitigate such risks effectively. (iv) Continue periodic assessment at least annually after on-boarding.	• Develop a Vendor Due Diligence Policy with clear procedures and thresholds. • Use a risk-tiering model to classify vendors (e.g., low, medium, high risk). • Maintain a centralised vendor inventory. • Automate monitoring of vendors using risk platforms for continuous scoring.
(b) Contractual Security Requirements	SLAs and contracts with technology providers must include among others: (i) Enforceable requirements, on data protection, incident response, audit rights, termination and undertaking for compliance with relevant regulations and Bursa's technical and security requirements. (ii) Rights of Bursa to have access to vendor's systems, information, and documents, and to appoint third-party reviewers when deemed necessary (cost of third-party reviewer to be borne by the Brokers).	• Any cloud service agreement must include safeguards to protect sensitive data. This includes giving the Brokers' control over encryption keys, using secure and private connections, limiting where data can be sent, and clearly stating where the data will be stored and which laws apply to it.

Areas	Standards	Guidance
	(iii) Technology service providers of Brokers must retain security logs for a minimum of three (3) years. This requirement must be explicitly stated in the contractual agreements and service level arrangements. The logs must be made available to Brokers upon request to support audit, investigation, and regulatory compliance activities. (iv) Technology service providers of Brokers must provide promptly updates on cyber events and incidents to all their clients i.e. Brokers. Vendors must provide cybersecurity risk assessment reports to Brokers either following significant incidents or at intervals stipulated in the service-level agreement (SLA), to support effective oversight and informed decision-making. (v) Requirement for the service provider to submit a written undertaking to comply with applicable secrecy laws, and for the SLA to clearly state that confidentiality obligations remain binding beyond the termination of the engagement. (vi) Arrangements for disaster recovery, backup capability and critical system availability. (vii) Requirement for establishing arrangements to ensure business continuity in the event of the service provider's exit or termination.	

Areas	Standards	Guidance
(c) Regular Performance Monitoring and Audits	(i) Establish a process for continuously monitoring the security posture of critical third-party providers. (ii) Conduct regular audits or require third-party service providers to submit independent audit reports. (iii) Brokers must carry-out regular independent audit which attests their cybersecurity hygiene, covering at a minimum access control, change management, backup procedures, and system development processes. (iv) The audit or assessment results should be shared with the Brokers', regulators and other relevant parties, where applicable.	• The audit report must include independent and objective opinion on the effectiveness of risk management, governance and internal controls of the Brokers' data security, availability, confidentiality and processing integrity (i.e. SOC 2 Type 2 report). • Cost of audits or assessments may be shared among all clients or relevant parties.
(d) Incident Reporting and Collaboration	(i) Adopt standardised industry wide protocols in place for third-party providers. (ii) Mandate tabletop exercises for joint incident response exercises with critical third-party providers annually. (iii) Mandate prompt reporting of cybersecurity incidents. (iv) Third-party providers must collaborate effectively during incident response.	• Brokers shall maintain a third-party register capturing service scope, data categories, hosting locations, sub-outsourcing, exit plan and Recovery Time Objective (RTO) and Recovery Point Objective (RPO) dependencies. • Contracts for critical providers shall mandate Priority 1 notification to be ≤1 hour and a full initial report ≤24 hours.
(e) Exit Strategy	(i) Develop an exit strategy for each critical third-party relationship. (ii) Exit strategy must include data retrieval procedures, system decommissioning, secure transition to alternative providers.	• Brokers shall perform an exit-execution test for each critical provider every 24–36 months.

2.7 Incident Management

Objective:

To establish a comprehensive framework for identifying, reporting, managing, and resolving incident in a timely and effective manner thereby minimising impact and supporting continuous improvement through post-incident reviews. The incidents include cybersecurity breaches, system outages, data loss and other operational disruptions,

Requirements:

Areas	Standards	Guidance
(a) Dedicated Incident Response Team ("IRT")	(i) Establish a dedicated IRT. (ii) The IRT must be available to respond to cybersecurity incidents at all times. (iii) When a cyber incident is confirmed, the Digital Forensics and Incident Response ("DFIR") process should be initiated immediately.	
(b) Incident Response Procedure/ Plan ("IRP")	(i) Establish a comprehensive IRP. (ii) The IRP must cover the following phases: ▪ Detection ▪ Analysis ▪ Containment ▪ Eradication ▪ Recovery ▪ Post-Incident Review	
(c) Regular Training & Exercises	(i) Training must be conducted for IRT and relevant staff at least once a year. (ii) Perform table-top exercise and simulated cyberattack drills.	

Areas	Standards	Guidance
(d) Forensic Capabilities	(i) Must have capabilities and capacity to perform digital forensic during incident investigation. (ii) Forensic investigations must be carried-out to determine root cause and gather evidence.	
(e) Communication and Reporting	(i) Establish clear communication protocols to ensure timely notification of incidents to stakeholders and relevant regulatory bodies during an incident. (ii) Protocols must be aligned with legal and internal policy requirements. (iii) All technology or cybersecurity incidents must be reported to relevant regulatory bodies immediately upon detection on the day of the occurrence of the incident (reportable incidents includes confirmed or near miss events).	• Reporting to Bursa Malaysia between 15 to 30 minutes of incident detection as per BM-Cert guidelines or as determined by Bursa Malaysia from time to time.
(f) Post-Incident Review and Improvement	(i) Post-incident reviews must be conducted after every significant incident. (ii) A post-incident review must be conducted to identify weaknesses and successes. The resulting analysis, including a remediation plan for enhancing controls, processes, or technologies, must be communicated to all relevant internal and external stakeholders to prevent future occurrences.	

2.8 Training and Awareness

Objective:

To foster a security-aware culture by providing ongoing education and targeted training to both internal personnel and external stakeholders (including clients and investors) equipping them with the knowledge to recognise, prevent, and respond to IT and cybersecurity risks effectively.

Requirements:

Areas	Standards	Guidance
(a) Staff Training Program	(i) Conduct training programs on a regular basis for all staff, including senior management and the Board of Directors. These programs should be customised for different roles and responsibilities and should cover key cybersecurity topics such as: • Phishing and email security • Password management • Secure handling of client data • Incident reporting procedures • Remote work security (ii) Tailored Role-Based Training: • Senior management and the Board of Directors must receive training focused on risk management, governance, and their strategic oversight role in cybersecurity. • IT, helpdesk, developers, and system administrators must receive specialised technical training relevant to their specific duties.	• Brokers shall set and track phish-click targets ($\leq 5\%$ within 12 months; $\leq 2\%$ thereafter). • Senior management shall participate in crisis tabletop exercises annually.

Areas	Standards	Guidance
(b) Client/ Investor Awareness	(i) Issue reminders on key areas such as: • Phishing and email security • Password management (ii) Establish a comprehensive investor compensation and support policy that includes provisions for investor/client liability, clear escalation procedures, and mechanisms for reporting concerns or issues by investors/clients.	

2.9 Dedicated Cybersecurity Role Establishment Through Internal or External Resources

Objective:

To ensure that cybersecurity responsibilities are formally assigned to qualified personnel, whether through internal appointments or external engagements, providing focused oversight, strategic direction, and operational execution of cybersecurity initiatives across the organisation.

Requirements:

Areas	Standards	Guidance
(a) Cybersecurity Leadership Role	(i) Designate a Chief Information Security Officer ("CISO") or a dedicated person with adequate IT knowledge and certification to oversee cybersecurity implementation, governance, and improvement. (ii) The CISO shall: (a) be independent from day-to-day technology operations. (b) keep apprised of current and emerging technology risks which could potentially affect the broker's risk profile; and (c) be appropriately certified. (d) advise or report to the Board on technology risks and cybersecurity related matters.	• The CISO shall have direct Board access. • The CISO shall provide quarterly reports to the Board, which may include Vulnerability SLAs, logging coverage, Authority to Operate ("ATO") rate, Threat-Led Penetration Testing ("TLPT") status, vendor concentration).

3. IMPLEMENTATION TIMELINE AND APPLICABILITY

- Brokers are expected to adopt and implement the standards outlined in this paper as part of industry best practices. Early adoption is strongly encouraged to ensure readiness and alignment with forthcoming updates to the ITSS framework to reflect the standards.
- Given their critical role in operational resilience and incident response preparedness, the following standards relating to people, process and governance are subject to full compliance **within 3 months of the issuance of the Recommendation Paper**
 - i. **Item 2.5 – Recovery Planning**
 - ii. **Item 2.7 – Incident Management**
- Adoption of standards involving system changes or upgrades are targeted for full compliance by **31 December 2026**. This will allow Brokers to align internal resources, infrastructure, and operational readiness with the prescribed controls, build capacity and engage relevant stakeholders, as well as integrate the standards into existing governance and operational frameworks. Brokers are encouraged to commence preparatory activities well in advance of their respective deadlines, including conducting gap assessments, planning internal resources and budgets, and engaging with technology service providers, where applicable.
- **Where the standards outlined in this paper are also requirements prescribed under the ITSS**, Brokers are expected to comply with the said standards in accordance with the applicable rules set out under the ITSS.
- It is also important to note that the *Guidelines on Technology Risk Management* ("GTRM") issued by the Securities Commission Malaysia and the *Risk Management in Technology* ("RMiT") policy by Bank Negara Malaysia may contain similar or overlapping standards. **Where there are differing requirements, the more stringent requirements shall apply.**

4. REGULATORY ALIGNMENT

These recommendations broadly align with:

- Securities Commission Malaysia's Guidelines on Technology Risk Management ("GTRM")
- Bank Negara Malaysia's Risk Management in Technology ("RMiT") framework.

5. CONTACT INFORMATION

For queries regarding this Recommendation Paper:

- Email: Secretariat.RSWG@bursamalaysia.com.

APPENDIX A: Categorisation of Brokers

For the purpose of this Recommendation Paper the categorisation of brokers is as follows:

Participating Organisations

Group	Criteria	No.	Participating Organisation
Group 1	- Bank-backed & Investment Bank; or - Top 10 ranking (to review annually); and - Operates an online trading platform with retail clientele	1. 2. 3. 4. 5. 6. 7. 8. 9. 10. 11.	Affin Hwang Investment Bank Berhad AmlInvestment Bank Berhad BIMB Securities Sdn Bhd CGS International Securities Malaysia Sdn Bhd CIMB Securities Sdn Bhd Hong Leong Investment Bank Berhad Kenanga Investment Bank Berhad Maybank Investment Bank Berhad MBSB Investment Bank Berhad Public Investment Bank Berhad RHB Investment Bank Berhad
Group 2	- Retail clientele; or - Operates an online trading platform	1. 2. 3. 4. 5. 6. 7. 8. 9. 10. 11. 12. 13.	Apex Securities Berhad FA Securities Sdn Bhd iFast Capital Sdn Bhd Inter-Pacific Securities Sdn Bhd M&A Securities Sdn Bhd Malacca Securities Sdn Bhd Mercury Securities Sdn Bhd Moomoo Securities Malaysia Sdn Bhd NewParadigm Securities Sdn Bhd Phillip Capital Sdn Bhd SJ Securities Sdn Bhd TA Securities Holdings Berhad UOB Kay Hian (M) Sdn Bhd
Group 3	Foreign brokers	1. 2. 3. 4. 5. 6.	Citigroup Global Markets Malaysia Sdn Bhd CLSA Securities Sdn Bhd JPMorgan Securities (M) Sdn Bhd Macquarie Capital Securities (M) Sdn Bhd Nomura Securities Malaysia Sdn Bhd UBS Securities Malaysia Sdn Bhd

Trading Participants

All standalone Trading Participants are categorised under Group 2.